PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Objectifs de cybersécurité Vigipirate

03-85 Vigipirate - Objectifs de cybersécurité — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. La direction doit valider la stratégie de cybersécurité au moins une fois par an.
2. L'analyse de risques doit être réalisée systématiquement dès les phases amont des projets.
3. La gestion des incidents nécessite une stratégie de communication pour maîtriser l'impact médiatique.

Gouvernance et pilotage stratégique

Notion	À retenir
Stratégie et moyens	La direction définit la stratégie, valide les orientations **au moins une fois par an** et assure les moyens **financiers, techniques et humains**. Une **cartographie fonctionnelle** identifie les ressources sensibles.
Organisation et documentation	Le **RSSI** rend compte directement à la direction. Un corpus documentaire (**PSSI**, plans de continuité/reprise) doit être validé par la direction, accessible et mis à jour.
Communication et RH	Sensibilisation périodique du personnel, stagiaires et sous-traitants. Engagement **par écrit** du personnel. Intégration des exigences de sécurité dans les **contrats avec les tiers**.

Maîtrise des risques et des SI

Notion	À retenir
Analyse des risques	Utiliser la méthode **EBIOS**. Planifier dès les phases amont. Mise à jour **au minimum tous les ans** ou lors de **modification technique/fonctionnelle importante**. Risques résiduels acceptés formellement par l'autorité responsable via l'**homologation**.
Documentation systèmes	Maintenir une **cartographie technique macroscopique** cohérente avec la fonctionnelle. Documentation complète, organisée et **accessible uniquement aux acteurs concernés**.
Cycle de vie/Accès	De la **conception** au **retrait de service**. Appliquer le **principe du moindre privilège** et un **inventaire exhaustif des comptes privilégiés**.

Protection physique et logique des systèmes

Notion	À retenir
Composants et services	Choisir des **composants de confiance** et **qualifiés par l'ANSSI**. Utiliser la **cryptographie à l'état de l'art** et une **authentification forte**.
Protection physique	Contrôler les **accès aux zones sensibles**, garantir l'**énergie** et le **refroidissement**, et protéger contre les **risques électromagnétiques**.
Sécurisation logique	Appliquer la **défense en profondeur**, **segmenter les réseaux** en zones homogènes, filtrer les flux et sécuriser le **cycle de vie des données**.

Gestion des incidents et continuité

Notion	À retenir
Préparation et détection	Collecte de **journaux** centralisés par site, conservation **si possible un an**, surveillance vérifiée périodiquement et détection par analyse **humaine ou automatique**.
Analyse, réaction, REX	Reconstituer le scénario, identifier les vecteurs et l'étendue. Réaction pour **bloquer l'attaquant** et durcir les systèmes. **Bilan ponctuel** immédiat et **REX régulier**. **Communication de crise** préparée (impact médiatique, interlocuteurs autorisés).
Résilience et continuité	Élaborer **PCA/PRA** (procédures, scénarios). Sauvegardes (données et journaux) protégées en **confidentialité et intégrité**. Tests et entraînements réguliers nécessaires.

Recommandations de gestion de crise et sauvegarde

- **Sauvegardes** : doivent être contrôlées avant restauration pour détecter des fichiers détruits ou des codes malveillants.
- **Moyens de communication de crise** : doivent être **sécurisés et indépendants** des SI de l'entité.
- **Communication de crise** : doit garantir la **disponibilité**, la **confidentialité**, l'**intégrité** et la **non-répudiation**.
- **Fréquence de journalisation** : doit être adaptée au **niveau de criticité** du système concerné.
- **Réaction face à un sinistre** : nécessite la mobilisation du personnel et l'activation du **centre de gestion de crise**.

Évaluation et relations autorités

Notion	À retenir
Audits et exercices	Réaliser des **vérifications/audits** (via prestataires **PASSI**), traquer les **traces de compromission** et organiser des **entraînements** pour valider la réaction du personnel.
Coordination autorités	Collaborer avec l'État, communiquer l'**annuaire de gestion de crise** à l'**ANSSI** et appliquer rapidement ses **recommandations, avis et alertes**.
Gestion de crise	Contribuer au plan **Vigipirate**, maintenir les **informations de crise** à jour et traiter les incidents en lien avec la **réponse nationale** pilotée par l'**ANSSI**.

Éléments de contrôle et d'audit

- Auditer fréquemment les annuaires centraux (**Active Directory** ou **LDAP**).
- Traquer les traces de compromission dans les journaux (**antivirus**, **pare-feu**, **serveurs**, **postes de travail**) et les marqueurs (**fichiers**, **domaines DNS malveillants**).
- Tout problème identifié doit faire l'objet d'un **plan d'actions de correction**.
- Être capable d'auditer les **infrastructures multinationales** et les **sites internationaux**.
- Valider la capacité de réaction des **acteurs** (personnel et prestataires) lors d'un incident sur les **missions sensibles**.

Pièges et confusions

⚠ Confondre la cartographie fonctionnelle qui identifie les activités avec la cartographie technique qui détaille les systèmes.
⚠ Oublier que la stratégie de cybersécurité doit être validée annuellement par la direction.
⚠ Limiter la gestion des incidents à la seule réaction technique sans inclure la communication.
⚠ Ne pas appliquer le principe du moindre privilège aux accès utilisateurs ou à la gestion des droits.
⚠ Oublier que l'analyse de risques doit être mise à jour au minimum une fois par an.

Sigles et définitions

OIV opérateur d'importance vitale
ANSSI autorité nationale de la sécurité des systèmes d'information
RSSI responsable de la sécurité des systèmes d'information
PSSI politique de sécurité des systèmes d'information
EBIOS méthode reconnue et systématique pour réaliser une analyse de risques
PCA plan de continuité d'activité
PRA plan de reprise d'activité

Auto-test

1. Quelle méthode est reconnue pour réaliser une analyse de risques ?
2. À quelle fréquence la stratégie de cybersécurité doit-elle être validée par la direction ?
3. Que doit-on appliquer tant aux accès utilisateurs qu'à la gestion des droits ?
4. Quelle est la durée de conservation recommandée pour la collecte de journaux centralisés ?
5. Que doit-on faire de tout problème identifié lors d'un audit ?

Réponses : **1.** La méthode EBIOS · **2.** Au moins annuellement · **3.** Le principe du moindre privilège · **4.** un an · **5.** faire l'objet d'un plan d'actions de correction

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.